ผนวก 6 การทดสอบการใช้งานจริง

ผู้ยื่นข้อเสนอจะต้องจัดให้มีการสาธิตและทดสอบการใช้งานจริงของระบบ Multi-Factor Authentication ตามเงื่อนไขและหลักเกณฑ์การพิจารณาด้านเทคนิคที่ กฟผ. กำหนด ทั้งนี้ กฟผ. จะพิจารณาผลการทดสอบโดยใช้เกณฑ์การประเมินแบบ **"ผ่าน" หรือ "ไม่ผ่าน"** และผลการพิจารณาของ กฟผ. ให้ถือเป็นที่สิ้นสุด

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การ Synchronize บัญชีผู้ใช้งานกับ Active Directory				
1	Synchronize ทุกบัญชีผู้ใช้งานตาม Organization Unit (OU) ที่กำหนดที่มีชื่อเป็นภาษาไทย และเปิดใช้ MFA สำหรับทุกบัญชีผู้ใช้งานนั้นแบบอัตโนมัติได้	9.1	ทดสอบกับ Active Directory ที่ กฟผ. จัดเตรียมไว้ให้	
2	Synchronize ทุกบัญชีผู้ใช้งานตาม Organization Unit (OU) ที่กำหนดที่มีชื่อเป็นภาษาไทย และเลือกเปิดใช้ MFA สำหรับบางบัญชีผู้ใช้งาน	9.2	ทดสอบกับ Active Directory ที่ กฟผ. จัดเตรียมไว้ให้	
3	สามารถสร้าง Mapping ของ User Attributes หรือ User Properties ที่มีข้อมูลเป็นภาษาไทย เพื่อ Synchronize ไปยังระบบที่นำเสนอได้	9.3	ทดสอบกับ Active Directory ที่ กฟผ. จัดเตรียมไว้ให้	
4	สามารถ Custom parameter โดยใช้ attribute ใน AD ที่กำหนดได้	9.4	ผู้ยื่นข้อเสนอสาธิตการ Custom parameter	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การใช้งานระบบ MFA กับ VPN Gateway (1/2)				
1	ระบบต้องสามารถเชื่อมต่อกับ VPN Gateway ของ กฟผ. ด้วยโปรโตคอล SAML และส่งค่า Attribute ที่กำหนดกลับมาให้ VPN Gateway เพื่อใช้ในการกำหนด Policy ได้	11.1	ทดสอบกับ VPN Gateway ที่ กฟผ. จัดเตรียมไว้ให้	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การใช้งานระบบ MFA กับ VPN Gateway (2/2)				
2	หลังจากผู้ใช้งานยืนยันตัวตนด้วย Password เป็น Factor ที่หนึ่งแล้ว หากผู้ใช้งานใช้งาน MFA เป็นครั้งแรก ระบบจะต้องแสดงขั้นตอนการลงทะเบียน เพื่อให้ผู้ใช้งานคนนั้นลงทะเบียน Mobile app authenticator จนสำเร็จได้	10.6	ทดสอบกับ VPN Gateway ที่ กฟผ. จัดเตรียมไว้ให้	
3	สามารถใช้งาน MFA โดยใช้ Factor ที่หนึ่งเป็น Password และใช้ Factor ที่สองเป็น Push-based Authentication พร้อมบังคับให้พิมพ์หรือเลือกตัวเลขที่เห็นจากหน้าจอเข้าสู่ระบบ (Number Matching) ได้	10.13	ทดสอบกับ VPN Gateway ที่ กฟผ. จัดเตรียมไว้ให้ และเจ้าหน้าที่ กฟผ. ตรวจสอบความถูกต้องของ Policy ของผู้ใช้งาน	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การใช้งานระบบ MFA กับ In-house Web Application ด้วยโปรโตคอล OIDC และการใช้งาน API (1/2)				
1	ระบบต้องสามารถเชื่อมต่อกับ In-house web application ผ่านโปรโตคอล Open ID Connect (OIDC) และส่งค่า Custom Attribute ที่กำหนดกลับมาให้ In-house web application เพื่อใช้ในการยืนยันตัวตนได้	11.7	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน โดย Web application ต้องพัฒนาด้วย Next JS พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	
2	หลังจากผู้ใช้งานยืนยันตัวตนด้วย Password เป็น Factor ที่หนึ่งแล้ว หากผู้ใช้งานใช้งาน MFA เป็นครั้งแรก ระบบจะต้องแสดงขั้นตอนการลงทะเบียน เพื่อให้ผู้ใช้งานคนนั้นลงทะเบียน Mobile app authenticator จนสำเร็จได้	10.6	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
3	สามารถใช้งาน MFA โดยใช้ Factor ที่หนึ่งเป็น Password และใช้ Factor ที่สองเป็น Push-based Authentication พร้อมบังคับให้พิมพ์หรือเลือกตัวเลขที่เห็นจากหน้าจอเข้าสู่ระบบ (Number Matching) ได้	10.13	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	

เกณฑ์พิจารณา		ข้ออ้างอิงในผนวก 2	รูปแบบการทดสอบ	ผ่าน/ไม่ผ่าน
การใช้งานระบบ MFA กับ In-house Web Application ด้วยโปรโตคอล OIDC และการใช้งาน API (2/2)				
4	ผู้ใช้งานหนึ่งคนต้องสามารถติดตั้ง Mobile app authenticator ได้บน 2 อุปกรณ์เป็นอย่างน้อย และต้องกำหนดได้ว่าจะให้อุปกรณ์ใดเป็นเครื่องหลัก (Primary) ได้ โดยแต่ละอุปกรณ์ที่ติดตั้ง จะต้องใช้งาน MFA ในลักษณะเดียวกัน เช่น ทุกอุปกรณ์ต้องสามารถทำ Push-based Authentication ได้	10.3	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
5	ต้องเรียกใช้งาน Push-based Authentication ไปยัง Mobile app authenticator ที่เป็นอุปกรณ์หลัก (Primary) ผ่าน REST API ได้	12.1	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	
6	ต้องเรียกใช้งาน Time-based OTP ไปยัง Mobile app authenticator ที่เป็นอุปกรณ์หลัก (Primary) ผ่าน REST API ได้	12.2	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	
7	สามารถทำ Authorization Flow หรือเทียบเท่า บน OIDC แบบ Client Secret ได้	15	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	

เกณฑ์พิจารณา		ข้ออ้างอิงในผนวก 2	รูปแบบการทดสอบ	ผ่าน/ไม่ผ่าน
การใช้งานระบบ MFA และ SSO กับ In-house Web Application ด้วยโปรโตคอล SAML (1/2)				
1	ระบบต้องสามารถเชื่อมต่อกับ In-house web application ของ กฟผ. ผ่านโปรโตคอล SAML และส่งค่า Custom Attribute ที่กำหนดกลับมาให้ In-house web application เพื่อใช้ในการยืนยันตัวตนได้	11.6	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน โดย Web application ต้องพัฒนาด้วย Next JS พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	
2	สามารถใช้งาน MFA โดยใช้ Factor ที่หนึ่งเป็น Password และใช้ Factor ที่สองเป็น Push-based Authentication พร้อมบังคับให้พิมพ์หรือเลือกตัวเลขที่เห็นจากหน้าจอเข้าสู่ระบบ (Number Matching) ได้	10.13	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
3	หน้า SSO Login Page สามารถปรับแต่ง Logo ให้เป็นของ กฟผ. ได้	13.1	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การใช้งานระบบ MFA และ SSO กับ In-house Web Application ด้วยโปรโตคอล SAML (2/2)				
4	หน้า SSO Login Page สามารปรับแต่งภาพพื้นหลัง (Background Image) ได้	13.2	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
5	หน้า SSO Login Page สามารถเพิ่ม Hyperlink เพื่อ Redirect ไปยังหน้าเว็บที่ต้องการได้	13.3	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การใช้งานระบบ MFA กับ In-house Mobile Application ด้วยโปรโตคอล OIDC				
1	ระบบต้องสามารถเชื่อมต่อกับ In-house mobile application ผ่านโปรโตคอล Open ID Connect (OIDC) ได้	11.8	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน โดย Web application ต้องพัฒนาด้วย React Native พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	
2	สามารถใช้งาน MFA แบบ Passwordless โดยใช้ Factor ที่หนึ่งเป็น PIN หรือ Biometrics บนมือถือ และใช้ Factor ที่สองเป็น Push-based Authentication พร้อม Number Matching ได้	10.14	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
3	สามารถทำ Authorization Flow หรือเทียบเท่า บน OIDC แบบ PKCE ได้	15	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน พร้อมแสดง Source code เพื่อให้เจ้าหน้าที่ กฟผ. ตรวจสอบ	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
Adaptive Authentication (1/2)				
1	สามารถทำ Adaptive Authentication หรือ Risk-based Authentication ได้ โดยปัจจัยที่นำมาประเมินความเสี่ยงหรือกำหนดเงื่อนไข (Rule-based Conditions) ได้แก่ Geographic Location	10.15.1	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	
2	สามารถปฏิเสธการเข้าใช้งาน (Block) เมื่อผู้ใช้งานเชื่อมต่อมาด้วย TOR Network	10.15.3	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
Adaptive Authentication (2/2)				
3	สามารถปฏิเสธการเข้าใช้งาน (Block) เมื่อตรวจพบพฤติกรรมที่มีความเสี่ยงสูง เช่น การย้ายประเทศในการเข้าสู่ระบบในเวลาใกล้เคียงกันก่อนการยืนยันตัวตน	10.15.4	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	

เกณฑ์พิจารณา		ข้ออ้างอิงใน ผนวก 2	รูปแบบการทดสอบ	ผ่าน/ ไม่ผ่าน
การบริหารจัดการระบบ MFA				
1	สามารถทำ Role-Base Access Control สำหรับผู้ดูแลระบบ ได้ ดังนี้ 1) Super User หรือเทียบเท่า 2) Manage Users หรือเทียบเท่า 3) Manage Application หรือเทียบเท่า 4) Helpdesk หรือเทียบเท่า	20	ผู้ยื่นข้อเสนอจัดเตรียมระบบและสาธิตการทำงาน	